

politica-de-vulneraciones-de-seguridad-de-grt

security-system/politica-de-vulneraciones-de-seguridad-de-grt.docx

1 Objetivo

La presente Política proporciona orientación general para Grünenthal de México, S.A. de C.V. . (en adelante “Grünenthal”) cuando tuviere conocimiento de una vulneración de datos que involucra datos personales.

Asimismo, esta política proporciona orientación general sobre los pasos y factores clave que Grünenthal debe tener en cuenta al responder a una vulneración de datos, incluida una posible notificación a los titulares.

La política contiene un análisis de riesgo que Grünenthal debe realizar a las vulneraciones de datos. Este análisis debe realizarse caso por caso y deben tomarse decisiones sobre las acciones a tomar, de acuerdo con su propia evaluación de los riesgos y responsabilidades en sus circunstancias. Tomando en cuenta que una vulneración de datos puede potencialmente tener una serie de efectos adversos significativos en las personas, que pueden resultar en daños físicos, materiales o no materiales.

Estas vulneraciones pueden incluir la pérdida de control sobre sus datos personales, la limitación de sus derechos, la discriminación, el robo de identidad o el fraude, la pérdida financiera, la revocación no autorizada de la seudonimización, el daño a la reputación y la pérdida de confidencialidad de los datos personales protegidos por el secreto profesional. También puede incluir cualquier otra desventaja económica o social significativa para esas personas. Una de las obligaciones más importantes de Grünenthal es evaluar estos riesgos para proteger los derechos y libertades de sus titulares.

2. Contenido.

Grünenthal tiene la obligación de poner en marcha una guía de vulneraciones a datos personales, así como un plan de respuesta para poder:

Detectar y contener rápidamente el incidente.

Evaluar el riesgo para los titulares.

Determinar si es necesario notificar a los titulares afectados.

Esta Política proporciona las herramientas necesarias para que Grünenthal cumpla con lo anterior.

3. Términos y definiciones

Términos

Definición/Explicación

Aviso de Privacidad

Documento a disposición de la persona titular de la información de forma física, electrónica o en cualquier otro formato generado por Grünenthal, a partir del momento en el cual se recaben sus datos personales, con el objeto de informarle los propósitos del tratamiento de los mismos.

Base de datos

Conjunto ordenado de datos personales referentes a una persona identificada o identificable condicionados a criterios determinados, con independencia de la forma o modalidad de su creación, tipo de soporte, procesamiento, almacenamiento y organización.

Consentimiento

Manifestación de la voluntad libre, específica e informada de la persona titular de los datos mediante la cual se efectúa el tratamiento de los mismos.

Datos personales

Cualquier información concerniente a una persona identificada o identificable. Se considera que una persona es identificable cuando su identidad pueda determinarse directa o indirectamente a través de cualquier información

Datos personales sensibles

Aquellos datos personales que afecten a la esfera más íntima de la persona titular, o cuya utilización indebida pueda dar origen a discriminación o conlleve un riesgo grave para esta. De manera enunciativa más no limitativa se consideran sensibles los datos personales que puedan revelar aspectos como origen racial o étnico, estado de salud presente o futuro, información genética, creencias religiosas, filosóficas y morales, opiniones políticas y preferencia sexual.

Derechos ARCO

Son los derechos de Acceso, Rectificación, Cancelación, Oposición. Adicionalmente, se consideran los derechos de revocación de consentimiento y limitación de uso y/o divulgación de Datos Personales.

4. Lineamientos Generales.

¿Qué es una vulneración de datos personales de acuerdo con la normativa aplicable?

Se considera que existe una vulneración de datos cuando se da cualquiera de los siguientes casos:

Pérdida o destrucción no autorizada de datos personales.

Robo, pérdida o copia no autorizada de datos personales.

Uso, acceso o tratamiento no autorizados de datos personales.

Daño, alteración o modificación no autorizados de los datos personales.

¿Cómo se producen las vulneraciones de datos?

Algunas de las situaciones que implican una vulneración de datos y de soportes que pueden sufrir de vulneraciones de seguridad son los siguientes:

Computadoras portátiles perdidas o robadas, dispositivos de almacenamiento extraíbles o registros en papel que contienen información personal.

Unidades de disco duro y otros medios de almacenamiento digital (integrados en otros dispositivos, por ejemplo, impresoras multifunción, o de otro tipo) que se desechan o se devuelven a los arrendadores de equipos sin que el contenido se borre primero.

Bases de datos que contienen información personal que está siendo "pirateada" o a la que acceden ilegalmente personas fuera de Grünenthal.

Empleados que accedan o divulguen información personal fuera de los requisitos o la autorización de su empleo.

Registros en papel robados de reciclaje inseguros o cubos de basura.

Un empleado o miembro de Grünenthal proporciona por error información personal a la persona equivocada, por ejemplo, enviando detalles a la dirección equivocada.

Una persona que engaña a Grünenthal para la divulgación de información personal que le corresponde a otra persona.

Tipos de vulneraciones de datos personales.

Las vulneraciones de datos personales se pueden clasificar de acuerdo con principios de seguridad que se explican a continuación:

Vulneración de la confidencialidad: cuando hay una divulgación no autorizada o accidental, o acceso no autorizado a los datos personales.

Vulneración de la integridad: cuando hay una alteración no autorizada o accidental de los datos personales.

Vulneración de la disponibilidad: cuando se produce una pérdida accidental o no autorizada del acceso a los datos personales o la destrucción de los datos personales.

Dependiendo de las circunstancias, una vulneración puede afectar los tres principios al mismo tiempo, es decir la confidencialidad, integridad y disponibilidad de los datos personales, así como a cualquier combinación de ellos.

Notificación de vulneración de datos personales.

Individuos

La Ley exige que una vulneración de datos personales se notifique al titular solamente en el caso de que dicha vulneración pueda resultar en un riesgo para los derechos y libertades, específicamente para los derechos financieros y morales del titular de los datos personales. Este riesgo existe cuando la vulneración puede provocar daños físicos, materiales o no materiales. Ejemplos de tales daños son la discriminación, el robo o fraude de identidad, la pérdida financiera y el daño a la reputación. Lo anterior significa que Grünenthal, inmediatamente después de tomar conocimiento de una vulneración, debe evaluar el riesgo que dicho evento implica para las personas afectadas.

En este apartado, se describen los factores que deben tenerse en cuenta a la hora de evaluar el riesgo. La Ley no

establece un plazo concreto para llevar a cabo la notificación a los titulares afectados, solo especifica que debe hacerse tan pronto como el responsable: }

Determine que se produjo la vulneración, y

Haya adoptado las medidas necesarias para poner en marcha una investigación preliminar exhaustiva.

Es muy importante justificar el período de tiempo que Grünenthal tarda en proceder con la notificación, por lo que es crucial mantener registros del progreso de la investigación a través de la sección de Rendición de Cuentas y Mantenimiento de Registros del presente documento.

Autoridad de Protección de Datos – SABG

En términos de la Ley, las vulneraciones de datos no tienen que ser notificadas a la Secretaría de Anticorrupción y Buen Gobierno y específicamente a su Unidad de Protección de Datos Personales.

5. Equipo de Respuesta de Grünenthal.

El Departamento de Datos Personales de Grünenthal es el encargado, cuando resulte necesario, de notificar a los Titulares afectados sobre los incidentes de seguridad que afecten significativamente sus derechos patrimoniales y/o morales.

Por su parte, las vulneraciones a la seguridad de los datos personales o vulneraciones de seguridad son un tipo particular de incidente de seguridad que se caracterizan por:

Afectar a los sistemas relacionados con los datos personales, en cualquier fase de su tratamiento, y

Afectar de manera significativa los derechos patrimoniales o morales de los titulares de los datos personales.

Grünenthal cuenta con un Equipo de Atención formado por miembros relevantes del personal de las áreas de la Oficina de Privacidad de Datos, Jurídico, Seguridad de la Información y TI. Estos miembros, sus funciones y responsabilidades se identifican en las Política Global sobre violación de Datos Personales y en el presente

documento.

El Equipo de Atención de Grünenthal tiene la autoridad para tomar las medidas necesarias en caso de una vulneración sin necesidad de solicitar permisos en particular.

6. Obligación legal.

En México, la única obligación legal expresa aplicable en materia de vulneraciones de seguridad de datos personales consiste en la notificación a los titulares cuando sea probable que dicha vulneración represente un riesgo para sus derechos y libertades, en particular para sus derechos patrimoniales o morales. En estos casos, Grünenthal deberá notificar la vulneración a los titulares de los datos personales de manera inmediata, de conformidad con lo dispuesto en el artículo 19 de la LFPDPPP.

El apartado siguiente, titulado “Plan de respuesta”, describe el procedimiento que deberá seguir Grünenthal para dar cumplimiento a lo anterior en caso de una vulneración de seguridad de datos personales.

7. Plan de Respuesta.

Siempre que una vulneración de datos ocurra, el Equipo de Respuesta de Grünenthal debe tomar las siguientes medidas:

Paso 1: Determinar la existencia del incidente de seguridad relacionado con los datos personales de los titulares, contener la vulneración y hacer una evaluación preliminar.

Paso 2: Evaluar los riesgos asociados con la vulneración.

Paso 3: Notificar a los titulares en caso de ser necesario.

Paso 4: Prevenir de futuros incidentes.

Paso 1: Determinar la existencia del incidente de seguridad relacionado con los datos personales de los titulares, contener la vulneración y hacer una evaluación preliminar:

Una vez que Grünenthal ha descubierto o sospecha que se ha producido una vulneración de datos, debe tomar

medidas inmediatas para contenerla. Algunos ejemplos de estas son las siguientes.

a. Contener la vulneración.

Grünenthal debe tomar todas las medidas posibles para contener inmediatamente la vulneración. Por ejemplo, Grünenthal puede hacer lo posible para detener la práctica no autorizada, recuperar los registros o apagar el sistema que se ha infringido, así como evaluar si se pueden tomar medidas para mitigar el daño que una persona puede sufrir como resultado de una vulneración. Todos los pasos tomados por Grünenthal para contener el incumplimiento deben registrarse, de acuerdo con los formatos contenidos en la sección de “Rendición de Cuentas y Mantenimiento de Registros” de este documento.

Si no es práctico apagar el sistema, o si ello resultara en la pérdida de evidencia, entonces es recomendable revocar o cambiar los privilegios de acceso al equipo o abordar las debilidades en la seguridad física o electrónica.

b. Iniciar una vulneración preliminar.

El Equipo de Respuesta está obligado a llevar a cabo la investigación inicial, y deberá recopilar toda la información necesaria, así como formular recomendaciones iniciales.

La investigación inicial deberá recopilar toda la información que permita a Grünenthal responder a las siguientes preguntas:

¿Qué información personal se encuentra implicada en la vulneración?

¿Cuál fue la causa de la vulneración?

¿Cuál es el alcance de la vulneración?

¿Cuáles son los daños (para las personas afectadas) que potencialmente podrían ser causados por la vulneración?

¿Cómo se puede contener la vulneración?

Además, el Equipo de Respuesta deberá identificar la siguiente información:

La naturaleza del incidente.

Las causas internas del incidente.

Las causas externas que dieron lugar al incidente.

Las persona(s) responsable(s) del incidente.

El tipo de información comprometida.

La calidad de los titulares.

El ámbito del incidente.

Posibles consecuencias.

Medidas correctivas inmediatas adoptadas.

El Equipo de Respuesta debe tener cuidado de no destruir pruebas que puedan ser valiosas para determinar la causa o que permitan a Grünenthal tomar las medidas correctivas apropiadas.

Asimismo, el Equipo de Respuesta debe asegurar que se mantengan los registros apropiados de la vulneración, incluidas las medidas adoptadas para rectificar la situación y las decisiones tomadas a través de los documentos de la sección de Rendición de Cuentas y Mantenimiento de Registros de este documento

Paso 2: Evaluar los riesgos asociados con la vulneración.

Para determinar qué otros pasos son inmediatamente necesarios, Grünenthal debe evaluar los riesgos asociados con la vulneración

Además, Grünenthal debe tener en cuenta los siguientes factores al evaluar este tipo de riesgos:

tipo de incidente.

El tipo de información personal involucrada.

La facilidad para identificar a las personas cuyos datos personales se encuentran comprometidos. • El contexto de la información afectada y la vulneración.

La causa y el alcance de la vulneración.

El riesgo de daño grave a las personas afectadas.

El riesgo de otros daños.

a. El tipo de vulneración.

El tipo de vulneración que se ha producido puede afectar el nivel de riesgo presentado para las personas.

Por lo tanto, Grünenthal identificar si se trata de:

Vulneración de la confidencialidad de los datos personales;

Vulneración de la integridad de los datos personales; y/o

Vulneración de la disponibilidad de los datos personales

b. El Tipo de información personal involucrada.

Es más probable que cierta información cause un daño individual si se ve comprometida, ya sea que ese daño sea físico, financiero o psicológico. Además, una combinación de información personal crea un mayor riesgo de daño que una sola pieza de información personal en lo individual. Cuanto más sensibles sean los datos, mayor será el riesgo de daño para las personas.

Así mismo, es importante tener en consideración si la información es permanente o temporal. La permanencia de la información puede ser más significativa si está protegida por cifrado: con el tiempo, los algoritmos de cifrado pueden romperse, por lo que, en el largo plazo, dicha información puede tener un mayor riesgo de verse comprometida. Por otro lado, la información temporal puede haber cambiado en el momento en que se ha descifrado.

Algunos tipos de datos personales pueden parecer inofensivos a primera vista. Sin embargo, lo que esos datos

pueden revelar sobre el individuo afectado debe considerarse cuidadosamente

c. Facilidad de identificación de las personas

Otro factor importante por considerar es la facilidad que alguien tendrá para identificar a individuos específicos o hacer coincidir los datos personales a los que tuvo acceso con otra información con el fin de identificar a una persona. Dependiendo de las circunstancias, la identificación podría ser posible directamente a partir de los datos personales vulnerados sin que se necesite una investigación especial para descubrir la identidad del individuo, o puede ser extremadamente difícil hacer coincidir los datos personales con un individuo en particular.

d. El contexto de la información afectada y la vulneración

Las siguientes preguntas deben ser respondidas para analizar el contexto de la información afectada:

¿Qué partes han obtenido acceso a la información afectada? ¿A quién se expuso la información? Por ejemplo, los registros de los empleados que contienen información sobre el historial de empleo, como el desempeño y los asuntos disciplinarios o la salud mental de un compañero de trabajo, pueden ser particularmente sensibles si se exponen a otros empleados en el lugar de trabajo y podrían resultar en que una persona sea objeto de humillación o acoso en el lugar de trabajo.

¿Ha habido otros incidentes que pudieran tener un efecto acumulativo? Unos pocos incidentes pequeños, aparentemente insignificantes, podrían tener un efecto acumulativo cuando se consideran en conjunto. Incluso, incidentes separados pueden alcanzar este umbral cuando se considere el efecto acumulativo de los incidentes.

¿Cómo se puede utilizar la información personal? ¿Podría la información ser utilizada para fines fraudulentos o dañinos, tales como causar una vergüenza significativa a la persona afectada? ¿Podría combinarse fácilmente la información comprometida con otra información comprometida o con información disponible públicamente para crear un mayor riesgo de daño a la persona?

e. La causa y el alcance de la vulneración.

Las siguientes preguntas deben ser respondidas para analizar la causa y el alcance de la vulneración:

¿Existe el riesgo de que la vulneración continúe o de una mayor exposición de la información? ¿Cuál fue el alcance del acceso no autorizado o la recopilación, el uso o la divulgación de información personal, incluido el número y la naturaleza de los destinatarios probables y el riesgo de un mayor acceso, uso o divulgación, incluso a través de los medios de comunicación o en línea?

¿Hay evidencia de robo? ¿Hay evidencia que sugiera un robo? ¿La información fue el objetivo de este robo? Por ejemplo, cuando se roba una computadora portátil, ¿se puede determinar si el ladrón quería específicamente la información de la computadora portátil o el hardware de la computadora portátil? La evidencia de robo podría sugerir una mayor intención de hacer daño y aumentar la necesidad de notificar al titular, así como de otros requisitos legales.

¿La información personal se encuentra encriptada de la manera adecuada, es anónima o es fácilmente accesible? ¿La información se vuelve ilegible por las medidas de seguridad que protegen la información almacenada? ¿La información personal se muestra o almacena de tal manera que no se pueda utilizar si se vulnera?

¿Cuál fue el origen de la vulneración? Por ejemplo, ¿implicó un comportamiento malicioso externo o interno, o fue un error de procesamiento interno? ¿La información parece haber estado perdida o extraviada? El riesgo de daño a la persona puede ser menor cuando la vulneración es involuntaria o accidental, en lugar de intencional o maliciosa.

¿Se ha recuperado la información personal? Por ejemplo, ¿se ha encontrado o devuelto una computadora portátil perdida? Si la información se ha recuperado, ¿hay algún signo de que se haya accedido a ella, copiado o manipulado de otro modo?

¿Qué medidas se han tomado para mitigar el daño desde que se tuvo conocimiento de este? ¿Se ha contenido el incidente? Por ejemplo, ¿se han reemplazado las medidas de seguridad comprometidas, como pudieran ser las contraseñas o accesos? ¿Se ha evaluado el alcance total del incidente? ¿Es necesario adoptar más medidas para contener la vulneración o mitigar el daño?

¿Se trata de un problema sistémico o de un incidente aislado? Al comprobar el origen del incidente, es importante comprobar si se han producido incidentes similares en el pasado. A veces, una vulneración puede señalar un problema más profundo con la seguridad del sistema. Esto también puede revelar que se ha visto afectada más información de lo que se pensaba inicialmente, lo que podría aumentar la conciencia del riesgo planteado.

¿Cuántas personas se ven afectadas? Si bien el número de personas afectadas puede ayudar a medir la gravedad de la vulneración, es importante recordar que incluso una vulneración que involucra la información personal de una o dos personas puede ser grave, dependiendo de la información involucrada y el contexto de la vulneración.

f. El riesgo de daño grave a las personas afectadas

La magnitud del daño que puedan sufrir las personas afectadas depende esencialmente de la naturaleza de los datos personales involucrados en una vulneración. Por ejemplo, con respecto a los datos personales sensibles, el daño potencial a las personas puede ser especialmente grave: la vulneración podría resultar en robo de identidad o fraude, daño físico, angustia psicológica, humillación o daño a la reputación. Si la vulneración se refiere a datos personales sobre personas vulnerables, éstas podrían correr un riesgo aún mayor del daño.

Aquí hay una lista de ejemplos de posibles daños que puede sufrir una persona como consecuencia de una vulneración a la seguridad de sus datos personales:

Robo de identidad.

Pérdida financiera.

Amenaza a la seguridad física.

Amenaza al bienestar emocional.

Pérdida de oportunidades de negocio o empleo.

Humillación, daño a la reputación o a las relaciones.

Intimidación o marginación en el lugar de trabajo o social.

Es fundamental que Grünenthal analice si la vulneración implica una afectación a los datos personales de niños u otras personas en situación de vulnerabilidad, que puedan estar expuestas a un mayor riesgo. En este sentido, es importante tener presente que información que pueda revelar aspectos como el origen racial o étnico, el estado de salud presente y futuro, información genética, información sobre creencias religiosas, filosóficas y morales, la afiliación sindical, opiniones políticas y preferencia sexual de una persona puede dar origen a discriminación o puede conllevar un riesgo grave para ésta. Así mismo, existen otros factores sobre el titular que pueden afectar el nivel de impacto de la vulneración en ellos (por ejemplo, si son funcionarios del gobierno, figuras públicas, etc.).

g. El riesgo de otros daños

El equipo de respuesta de Grünenthal debe identificar otros posibles daños para la organización, como, por ejemplo:

la pérdida de la confianza pública;

el daño reputacional;

la pérdida de activos;

posibles sanciones reglamentarias;

la extorsión;

responsabilidad legal, etc.

El Equipo de Respuesta debe registrar los resultados y las respuestas a todas estas preguntas en los documentos de la sección de Rendición de cuentas y Mantenimiento de Registros de este documento.

Al evaluar el riesgo que probablemente resulte de una vulneración, Grünenthal debe considerar todos los factores anteriormente mencionados para determinar el impacto potencial tanto en los individuos como en la organización.

Paso 3: Notificación

La Ley exige que una vulneración de datos personales se notifique al titular sólo si dicha vulneración puede resultar en un riesgo para sus derechos y libertades, específicamente para sus derechos financieros y morales. Lo anterior significa que Grünenthal debe evaluar el riesgo que la vulneración implica para las personas, inmediatamente después de tomar conocimiento de una vulneración. Dicho de otra forma, Grünenthal debe notificar a las personas de cualquier vulneración, a menos que sea poco probable que resulte en un riesgo significativo para sus derechos financieros y morales. Este riesgo existe cuando la vulneración puede provocar daños físicos, materiales o no materiales para las personas cuyos datos han sido vulnerados. Ejemplos de tales daños son la discriminación, el robo o fraude de identidad, la pérdida financiera y el daño a la reputación.

En caso de duda, es esencial que Grünenthal adopte una medida preventiva y notifique.

En aquellos casos en los que Grünenthal esté obligado a notificar de una vulneración al titular, dicha comunicación deberá informar sobre lo siguiente:

La naturaleza del incidente;

Los datos personales comprometidos;

Recomendaciones para el titular sobre las medidas que puede adoptar para proteger sus intereses;

Las acciones correctivas que la organización adoptó de manera inmediata, y

Los medios por los cuales pueden obtener más información sobre la vulneración en caso de dudas.

a. Análisis del Riesgo

El análisis del riesgo se fundamenta en la metodología recomendada por el INAI, autoridad previa en materia de datos personales, la cual se centra en el análisis de tres variables que inciden en la percepción del valor de los datos personales para un atacante:

Beneficio para el atacante. Aquellos datos personales que representan el mayor beneficio tienen más probabilidades de ser atacados (por ejemplo, ganancias financieras de venderlos o usarlos).

Accesibilidad para el atacante. Aquellos datos personales que son de fácil acceso tienen más probabilidades de ser atacados (por ejemplo, miles de personas pueden acceder a una base de datos a través de un sitio web al mismo tiempo, pero solo unos pocos podrían acceder a un archivero).

Anonimato del atacante. Aquellos datos personales cuyo acceso representa un mayor anonimato para el atacante tienen más probabilidades de ser atacados (por ejemplo, internet es un medio más anónimo que presentarse físicamente en las instalaciones de una empresa).

Así mismo, para determinar el valor que los datos personales pueden tener para el atacante, el INAI considera que se deben evaluar tres factores:

Los tipos de datos personales.

Su sensibilidad.

El volumen de los titulares.

Para determinar la naturaleza de los datos personales y su riesgo inherente, Grünenthal debe tener en cuenta la siguiente clasificación:

Datos con riesgo inherente reforzado: Estos datos de mayor riesgo son los que de acuerdo con su naturaleza derivan en mayor beneficio para un atacante. Por ejemplo, información adicional de la tarjeta bancaria (el número de tarjeta de crédito/débito en combinación con cualquier otro dato relacionado como fecha de vencimiento, códigos de seguridad, datos de banda magnética o PIN).

Datos con riesgo inherente alto: Esta categoría de datos contempla los datos personales sensibles, que de acuerdo a la Ley incluyen datos de salud, los cuales se refieren a la información médica donde se documente el estado de salud física y mental, pasado, presente o futuro; información genética; origen racial o étnico, ideología, creencias religiosas, filosóficas y morales, afiliación sindical, opiniones políticas, preferencia sexual, hábitos sexuales y cualquier otro cuya utilización indebida pueda dar origen a discriminación o conlleve un riesgo grave para el titular.

Datos con riesgo inherente medio: Esta categoría contempla datos que permitan conocer la ubicación física de la persona, inferir su patrimonio y datos de autenticación.

Datos con riesgo inherente bajo: Esta categoría considera información general de una persona física identificada o identificable, como datos de información y contacto.

El segundo elemento que debe ponderarse junto con el riesgo inherente de los datos personales es el que consiste en el número de titulares afectados de acuerdo con los siguientes criterios:

Con base en la tabla anterior, si Grünenthal determina que el riesgo derivado del volumen de titulares en relación con el riesgo inherente de los datos personales cometidos es de nivel 4 o 5, Grünenthal está obligado a notificar la vulneración de datos.

Si Grünenthal determina que el riesgo derivado del volumen de titulares en relación con el riesgo inherente de los datos personales comprometidos es de nivel 3, Grünenthal debe tener en cuenta otros factores, específicamente los mencionados en la sección anterior de este documento.

b. Contacto con personas.

En principio, la notificación de una vulneración se hará directamente, a menos que hacerlo implique un esfuerzo desproporcionado. En tal caso, podrá darse mediante una comunicación pública o una medida similar por la que se informe a los titulares de manera igualmente eficaz.

Los mensajes dirigidos a los titulares para notificarles de una vulneración deben hacerse únicamente con ese objetivo y no deben incluir otra información como actualizaciones periódicas, boletines informativos o mensajes estándar. Es decir, la notificación debe ser independiente y no debe agruparse con otro material no relacionado con la vulneración, ya que puede confundir a los destinatarios y afectar al impacto de la notificación de la vulneración.

Esto ayuda a que la comunicación de la brecha sea clara y transparente.

En general, Grünenthal debe optar por la notificación directa –por teléfono, carta, correo electrónico o en persona– a las personas afectadas.

La notificación indirecta, ya sea por información del sitio web, avisos publicados, medios de comunicación, generalmente sólo debe ocurrir cuando la notificación directa podría causar más daño, es inviable en términos de costos o no se conoce la información de contacto de las personas afectadas.

En algunos casos, puede ser apropiado utilizar varios métodos de notificación a la vez.

Grünenthal deberá registrar todas las decisiones adoptadas en los documentos de la sección de Rendición de cuentas y mantenimiento de registros de este documento.

Paso 4. Prevenir futuras vulneraciones.

Una vez que se adoptaron las medidas inmediatas para mitigar los riesgos asociados con la vulneración, Grünenthal debe investigar la causa de la vulneración de manera exhaustiva y, a partir de ello, revisar el plan y las medidas de prevención existentes a partir de las lecciones aprendidas o, si no hay un plan en marcha, desarrollar uno.

Un plan de prevención debe sugerir acciones que sean proporcionales a la importancia de la vulneración y considerar si se trata de una vulneración sistémica o de un evento aislado.

Este plan puede incluir:

Una auditoría de seguridad de la seguridad física y técnica.

Una revisión de las políticas y procedimientos y cualquier cambio para reflejar las lecciones aprendidas de la investigación, y revisiones periódicas después de eso (por ejemplo, seguridad, retención de registros y políticas de recopilación).

Una revisión de las prácticas de selección y capacitación de los empleados.

Una revisión a los terceros prestadores de servicios (por ejemplo, proveedores para el almacenamiento de datos).

El plan puede incluir como requisito realizar una auditoría al final del proceso para garantizar que el plan de prevención se haya implementado plenamente.

Los preparativos sugeridos para responder a una vulneración de datos incluyen lo siguiente:

Desarrollar un plan de respuesta a vulneraciones: Si bien el objetivo debe ser prevenir los incidentes, tener un plan de respuesta a los incidentes puede ayudar a garantizar una respuesta rápida a los incidentes y un mayor potencial para mitigar los daños.

El plan podría establecer los datos de contacto del personal adecuado para ser notificado, aclarar las funciones y responsabilidades del personal y documentar los procesos que ayudarán a Grünenthal a contener los incidentes, coordinar las investigaciones y las notificaciones de incidentes, y cooperar con las investigaciones externas.

Establecer un equipo de respuesta a incidentes: Grünenthal debe considerar la posibilidad de establecer un equipo de gestión responsable de responder a los incidentes de seguridad de datos personales además del Responsable de Privacidad. El equipo podría incluir representantes de las áreas pertinentes que puedan ser necesarias para investigar un incidente, realizar evaluaciones de riesgos y tomar decisiones apropiadas (por ejemplo, Seguridad Tecnológica y TI, Legal).

El equipo podría reunirse periódicamente para revisar el plan de respuesta a incidentes, discutir nuevos riesgos y prácticas, o considerar incidentes que han ocurrido en Grünenthal.

También puede ser útil llevar a cabo un entrenamiento de posibles "escenarios" con los miembros del equipo para permitirles desarrollar una sensación de una respuesta de vulneración real. Las cuestiones clave que habría que poner a prueba en esa capacitación serían determinar cuándo la notificación es una respuesta apropiada y el momento en que se realizaría esa notificación.

Identificar proveedores de servicios relevantes: Grünenthal debe considerar investigar e identificar proveedores de servicios externos que puedan ayudar en caso de una vulneración de datos. Los datos de contacto de los proveedores de servicios podrían establecerse en el plan de respuesta a incidentes. Esto podría ahorrar tiempo y ayudar a responder de manera eficiente y efectiva a una vulneración de datos.

Mejorar la comunicación interna y la capacitación: Asegúrese de que el personal ha sido capacitado para responder a las vulneraciones de datos de manera efectiva y está al tanto de las políticas y procedimientos pertinentes. Los usuarios deben comprender cómo identificar y reportar una posible vulneración de datos a los gerentes apropiados.

8. Rendición de cuentas y mantenimiento de registro.

Equipo de Respuesta

Departamento de datos personales

Funciones y responsabilidades

Nombres de integrantes:

Edificio y piso:

Correos electrónicos:

Extensiones

Consejero general

Funciones y responsabilidades

Nombre:

Edificio y piso:

Correo electrónico:

Extensión

Delegado de Protección de Datos (México)

Funciones y responsabilidades

Nombre:

Edificio y piso:

Correo electrónico:

Extensión

TI

Funciones y responsabilidades

Nombre:

Edificio y piso:

Correo electrónico:

Extensión

Miembro del Consejo Ejecutivo responsable del área afectada

Funciones y responsabilidades

Nombre:

Edificio y piso:

Correo electrónico:

Extensión

Responsable Global de Cumplimiento

Funciones y responsabilidades

Nombre:

Edificio y piso:

Correo electrónico:

Extensión

Coordinadores de Protección de datos

Funciones y responsabilidades

Nombre:

Edificio y piso:

Correo electrónico:

Extensión

Responsable Global de Protección de Datos Personales

Funciones y responsabilidades

Nombre:

Edificio y piso:

Correo electrónico:

Extensión

Registro de identificación de vulneración

Información General de quien detectó el incidente

Nombre:

Edificio-Puesto:

Teléfono:

Dirección de la que depende:

Extensión:

Correo:

Información sobre el incidente

Fecha:

Hora:

Localización donde se detectó el incidente

Sistema de tratamiento afectado:

Nombre del sistema de tratamiento:

Se encuentran involucrados datos personales en el incidente

☐ Sí

☐ No

Tipo de datos personales involucrados

Descripción de lo sucedido:

Se trata de un incidente de seguridad

'Q S í

'Q N o

Justificación:

Mencionar si existen impactos legales o contractuales

Resumen del Incidente

Resumen del Incidente

Resumen Técnico del incidente

Tipo de Incidente:

'Q Acceso no autorizado

'Q Robo, pérdida o extravío

'Q Espionaje

'Q Código malicioso

'Q Uso no autorizado

Otro:

Área/Departamento donde se presentó el incidente:

Nombre del contacto donde se presentó el incidente:

Extensión donde se presentó el incidente:

Correo:

¿Cómo se detectó el incidente?:

Información Adicional

Firma

Nombre y firma del personal que detecta el incidente

Nombre y firma del Responsable de Privacidad

Investigación del Incidente

Formato de Investigación del Incidente

Ubicación de los sistemas de tratamiento afectados:

Sistema afectado:

Sitio

Tiempos

Fecha y hora en la que se detectó el incidente

Nombre de primer respondiente en el incidente, Fecha y Hora

Fecha:

Hora:

Nombre:

Fecha y Hora:

Sistema de tratamiento afectado:

Tipo de sistema afectado

'Q F í s i c o

'Q D i g i t a l

Sistema de Tratamiento Físico

Sistema de Tratamiento:

Controles de seguridad físicos:

Lugar donde ocurrió el incidente:

Datos afectados en el incidente:

Personal involucrado en el incidente:

'Q Ex t e r n o

'Q I n t e r n o

Sistema de Tratamiento Electrónico

Sistema de tratamiento:

Controles de seguridad identificados:

Sistema conectado a una red:

'Q S í

'Q N o

Dirección de red del sistema:

Sistema con acceso a Internet:

'Q S í

'Q N o

Personal que realizó la gestión/atención del incidente

'Q I n t e r n o

'Q E x t e r n o

Describir las acciones realizadas por el personal Interno o externo que apoyó en el incidente

Acciones de apoyo en la contención del Incidente

Acciones de Contención

Aislamiento de los sistemas de tratamiento afectados

Aislamiento autorizado por el Responsable de Privacidad

'Q S í

'Q N o

Acción aprobada:

'Q Aislamiento

'Q Bloqueo

'Q Resguardo

'Q Reubicación

Hora:

Fecha:

Descripción del respaldo

Respaldo de sistemas afectados:

Se cuenta con respaldo de sistema de los datos personales tratamiento afectado:

'Q Sí

'Q No

Si no cuenta con respaldos en necesario respaldar:

'Q Sí

'Q No

Si se realizó respaldo, fue exitoso para todos los sistemas

'Q S í

'Q N o

Acciones para hacer el respaldo:

Personal que realizó el respaldo:

Fecha de inicio del respaldo:

Hora de inicio del respaldo:

Fecha de término del respaldo:

Hora de término del respaldo:

Mecanismos empleados para el respaldo

Físicos

'Q Copias fotostáticas

'Q Digitalización

'Q Resguardo en sitio alternativo

'Q Otro

Electrónicos

'Q Cintas

'Q CD/DVD

'Q Disco duro

'Q Nube

'Q Otro

Mecanismo de respaldo fue sellado

'Q Sí

'Q No

Fecha del sello:

Hora del Sello:

Persona a la que se entregó el respaldo para su resguardo:

Sitio donde se almacenó el respaldo:

Se realizaron pruebas al respaldo:

☐ Sí

☐ No

Mecanismos utilizados en las pruebas:

Nombre y firma de quien realizó el respaldo

Nombre y firma de quien recibe y valida el respaldo

Acciones de mitigación

Descripción de las acciones de mitigación

1. Personal involucrado

Nombre de las personas que realizaron el análisis del sistema de tratamiento afectado:

Nombre:

Puesto:

Extensión:

Dirección:

2. Descripción de vulnerabilidades detectadas:

Se identificaron vulnerabilidades:

☐ Sí

☐ No

Tipo de activo

Vulnerabilidad

Descripción

Impacto

Alto

Medio

Bajo

Acciones realizadas para erradicar las vulnerabilidades detectadas

3. Validación

¿Cuál fue el procedimiento de validación usado para asegurar que el problema fue erradicado

4. Cierre

Fecha de cierre del incidente:

Hora de cierre del incidente:

Nombre y firma de quien realizó el respaldo

Nombre y firma de quien recibe y valida el respaldo

Procesamiento de indicios o evidencias

Procesamiento de indicios o evidencias

1. Identificación de los indicios o evidencias:

Número de indicio o evidencia

Descripción del indicio o evidencia

Estado en que se encontraba

1.

2.

Fijación de indicios o evidencias:

Fotográfica

'Q S í

'Q N o

Videgrabación

'Q S í

'Q N o

Por escrito

'Q S í

'Q N o

Otros

Observaciones

3. Recolección o levantamiento

Descripción de la forma en que se realizó

Medidas tomadas para preservar la integridad del indicio o evidencia

4. Entrega de indicios o evidencias

Fecha:

Hora:

Nombre de la persona que entrega

Cargo de la persona que entrega

Tipo de indicio o evidencia

Documentos

Observaciones al estado en que se reciben los indicios o evidencias

Nombre y firma de quien entrega

Nombre y firma de quien recibe

Descripción de las acciones de recuperación

Descripción de las acciones de recuperación

1. Continuidad en la operación

El sistema de tratamiento continúa con su operación después del incidente

'Q S í

'Q N o

En caso de No indicar las causas

Personal designado para dar seguimiento a la recuperación del incidente

Iniciales

Nombre completo

Puesto

2. Tiempos

Fecha en que fue detectado

Fecha en que fue atendido por el equipo de respuesta a incidentes

Fecha en que fue cerrado

Hora en que fue detectado

Hora en que fue atendido por el Responsable de Privacidad

Hora en que fue cerrado

3. Monitoreo

Describir las acciones que se realizaran para monitorear las medidas implementadas:

Describir las herramientas para el monitoreo de las medidas implementadas

Nombre y firma de quien realiza la recuperación

Nombre y firma de quien validó la recuperación

9. Referencias

Procedimiento operativo estándar sobre la gestión de incidentes de seguridad.

10. Índice histórico

n/a